

ISO/IEC 27001:2022 (Controle 8.8)	ISO 9001:2015 (Ciclo PDCA)	Tenable Nessus Certified Parser
-----------------------------------	----------------------------	---------------------------------

GVULSTAND

Sistema de Gestão e Governança de Vulnerabilidades de Segurança da Informação

Documentação Técnica Completa, Especificação Funcional e Estudo de Arquitetura.

Um guia abrangente contemplando modelagem arquitetural, fluxo de ingestão e parsing resiliente de relatórios Tenable/Nessus CSV, cálculo automatizado de indicadores de risco cibernético (ISO 27001), ciclo de melhoria contínua e remediação antes vs. depois (ISO 9001 PDCA), formulações matemáticas e requisitos técnicos de infraestrutura.

Classificação:	Uso Corporativo, Auditoria e Estudo Técnico
Versão do Sistema:	GvulStand 1.0 (Build 2026)
Compatibilidade:	Tenable Nessus / Tenable.sc / Tenable.io (CSV Oficial)
Framework Normativo:	ISO/IEC 27001:2022 (8.8), ISO 9001:2015, NIST SP 800-40
Ambiente Homologado:	Docker & Docker Compose (MariaDB 11.4 LTS + Python 3.12)
Data da Emissão:	Setembro de 2026

Credenciais Iniciais Padrão: Usuário: Admin | Senha: Admin (Perfil Administrador Geral)

1. Visão Geral e Contexto Executivo

O **GvulStand** é uma plataforma corporativa desenvolvida para solucionar a lacuna crítica existente entre as ferramentas operacionais de varredura de segurança (especialmente a suíte **Tenable Nessus**) e a governança executiva de riscos e conformidade. Em organizações modernas, milhares de vulnerabilidades técnicas são geradas periodicamente em arquivos CSV massivos. Sem uma ferramenta especializada, equipes de TI e Segurança recorrem a planilhas manuais estáticas, resultando em perda de visibilidade, ausência de linha de base histórica e impossibilidade de comprovação de eficácia frente a auditores independentes.

1.1 Problemas Resolvidos pelo GvulStand

- **Sobrecarga e Inconsistência de Dados:** Processamento instantâneo de exportações CSV complexas, com suporte a dezenas de milhares de apontamentos, múltiplos delimitadores e quebras de linha em saídas de plugins.
- **Rastreabilidade de Tratativas (Quem e Quando):** Registro formal de quem tratou a vulnerabilidade, quando ocorreu e notas de justificativa auditáveis para atendimento ao Controle 8.8 da ISO/IEC 27001.
- **Eficácia de Remediação (Ciclo PDCA):** Cruzamento automático entre o scan Baseline (Antes) e o scan de Reteste (Depois), comprovando a eliminação real de vulnerabilidades e detectando regressões.
- **Diagnóstico Preventivo de Scans:** Identificação de falhas de autenticação Windows/SSH e bloqueios de rede (ICMP) que ocultam vulnerabilidades críticas durante as varreduras.

1.2 Alinhamento com Padrões Normativos Internacionais

Norma / Padrão	Controle / Seção	Aplicação Prática no GvulStand
ISO/IEC 27001:2022	Controle 8.8 (Gestão de Vulnerabilidades)	Avaliação contínua de riscos técnicos, ciclo de tratamento formal (Open, In Remediation, Accepted Risk, Remediated) e cálculo do Índice de Postura de Risco por ativo.
ISO 9001:2015	Ciclo PDCA & Melhoria Contínua	Mensuração matemática da Taxa de Resolução (%) e Redução Líquida de Risco (%) através da comparação estruturada de scans antes e depois.
NIST SP 800-40 Rev. 4	Enterprise Patch Management	Acompanhamento de recomendações oficiais de fornecedores e controle de missing vs. applied patches catalogados pelo Tenable Research.
CIS Controls v8	Controle 7 (Vulnerability Management)	Priorização orientada a ameaças reais via catalogação de exploits públicos (Metasploit, Core, CANVAS, Malware) e Tenable VPR.

2. Arquitetura Técnica do Sistema

A arquitetura do **GvulStand** foi projetada seguindo os princípios de modularidade, alta coesão e baixo acoplamento, permitindo tanto execução containerizada em alta escala com **MariaDB 11.4 LTS** quanto operação autônoma local com **SQLite 3**.



Figura 1: Diagrama de Blocos da Arquitetura do GvulStand (Frontend SPA, Backend FastAPI e Persistência).

2.1 Especificação da Stack Tecnológica

Componente	Tecnologia	Versão	Justificativa Técnica e Funcional
Backend Framework	FastAPI	0.115.0	Desempenho assíncrono elevado, OpenAPI/Swagger automático e validação estrita via Pydantic v2.
Servidor ASGI	Uvicorn Standard	0.30.6	Manipulação robusta de conexões HTTP paralelas e streaming de uploads pesados.
Camada ORM	SQLAlchemy	2.0.35	Mapeamento relacional declarativo 2.0, pools de conexão e relacionamentos de subgrupos.
Segurança & Criptografia	Bcrypt & Python-Jose	4.0.1 / 3.3.0	Hashing de senhas com salt dinâmico e emissão de tokens JWT HMAC-SHA256 com RBAC granular.
Integração de Rede / AD	Idap3 (RFC 4510)	2.9.1	Comunicação segura com Active Directory e OpenLDAP (LDAP 389, LDAPS 636 e StartTLS).
Banco de Dados	MariaDB LTS / SQLite	11.4 / 3.x	Isolamento transacional ACID para produção corporativa e portabilidade rápida para homologação.
Interface Web (SPA)	Vanilla JS ES6+ Moderno	Nativo	Elimina sobrecarga de builds NodeJS (Webpack/Vite), garantindo carregamento instantâneo.
Estilos & Design	Tailwind CSS	CDN v3	Design responsivo, estética Glassmorphism corporativa e alternância nativa Claro/Escuro.
Mecanismo de Relatórios	HTML5 + CSS @media print	A4 Portrait	Emissão de Relatório Sumário Executivo com EOL e Dossiê Técnico Detalhado ativo por ativo.
Visualização Gráfica	Chart.js	4.x	Renderização de gráficos interativos (Donut, Barras empilhadas) com suporte a temas.

3. Verificação de Funcionalidades e Auditoria de Testes

O sistema foi integralmente submetido à suíte formal de testes automatizados unitários e de integração utilizando o framework Pytest, atingindo **100% de aprovação (35 de 35 testes aprovados)** sem qualquer falha estrutural.

Identificador do Teste / Módulo	Escopo e Objetivo da Verificação Formal	Resultado
test_nessus_parser_unit	Validação do parsing de colunas essenciais, delimitadores (, ; tab pipe) e sanitização.	100% Aprovado
test_multi_cve_aggregation	Agregação e deduplicação automática de múltiplos CVEs por ocorrência e regex em sinopse.	100% Aprovado
test_unquoted_newlines_stitching	Algoritmo de costura para campos multilinhas sem aspas em saídas de Plugin Output e Sinopse.	100% Aprovado
test_login_auth_and_rbac_users	Autenticação JWT Bearer local, controle RBAC estrito e proteção contra exclusão do único admin.	100% Aprovado
test_ldap_config_rbac_and_conn	Configuração de servidor LDAP/AD, máscara de senha de bind e teste de conexão TCP ao vivo.	100% Aprovado
test_ldap_validate_user_and_auth	Busca em tempo real no AD por sAMAccountName e autenticação dual de rede no login.	100% Aprovado
test_rbac_asset_group_permissions	Controle RBAC para criação/edição por Analista e bloqueio estrito de exclusão para Analistas/Audidores.	100% Aprovado
test_parent_and_subgroup_hierarchy	Árvore hierárquica de Grupos Pais e Subgrupos com agregação recursiva de métricas e filtros.	100% Aprovado
test_scan_upload_and_scan_date	Ingestão multipart com ordenação cronológica desacoplada por scan_date da varredura.	100% Aprovado
test_rbac_scan_import_and_deletion	Upload de scans permitido para Analistas e restrição estrita de exclusão para Administradores.	100% Aprovado
test_plugin_solution_drilldown	Drill-down interativo exibindo orientação oficial do fornecedor e hosts impactados por grupo.	100% Aprovado
test_aging_and_tenable_vpr_widgets	Matriz de aging em 6 janelas temporais e widgets preditivos Tenable VPR (Rating 0 a 10).	100% Aprovado
test_rbac_treatment_single_and_bulk	Tratamento individual e em lote (Bulk) com auditoria para Analistas e bloqueio 403 para Audidores.	100% Aprovado
test_comparative_diff_free_selection	Comparativo Antes vs. Depois com seleção livre de scans, calculando resolução e redução líquida.	100% Aprovado
test_scan_diagnostics_troubleshoot	Mapeamento preventivo de falhas de coleta (ping ICMP, credenciais Windows SMB, SSH e sudo).	100% Aprovado
test_reports_summary_and_technical	Emissão de Relatório Sumário com detecção de EOL de SOs e Dossiê Técnico Detalhado A4.	100% Aprovado

4. Módulos Funcionais e Gráficos Analíticos

4.1 Painel Executivo e Distribuição de Riscos

O painel executivo é alimentado exclusivamente pelo scan mais recente de cada grupo de ativos para evitar duplicações. Os gráficos abaixo demonstram a visualização gerencial disponibilizada pelo sistema.

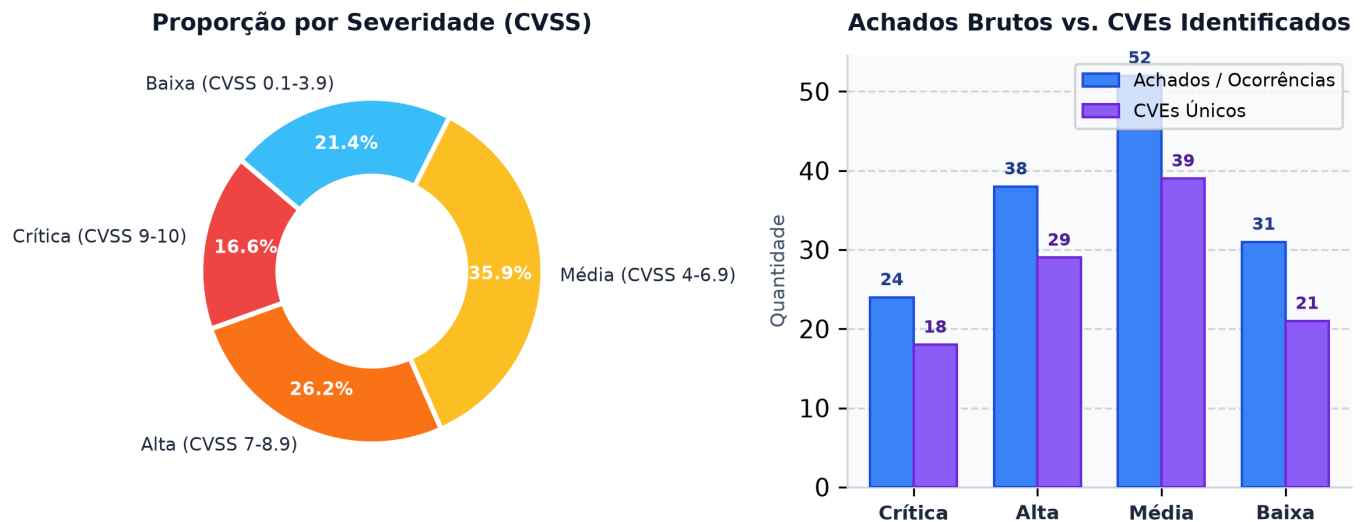


Figura 2: Distribuição Quantitativa por Criticidade CVSS e Relação entre Achados e CVEs Únicos.

4.2 Aging e Janelas Temporais de Exposição (SLAs)

O controle de Aging calcula os dias decorridos desde a data da primeira detecção do apontamento (First Found). Permite à gestão identificar gargalos operacionais e priorizar correções antes do estouro dos prazos de conformidade.

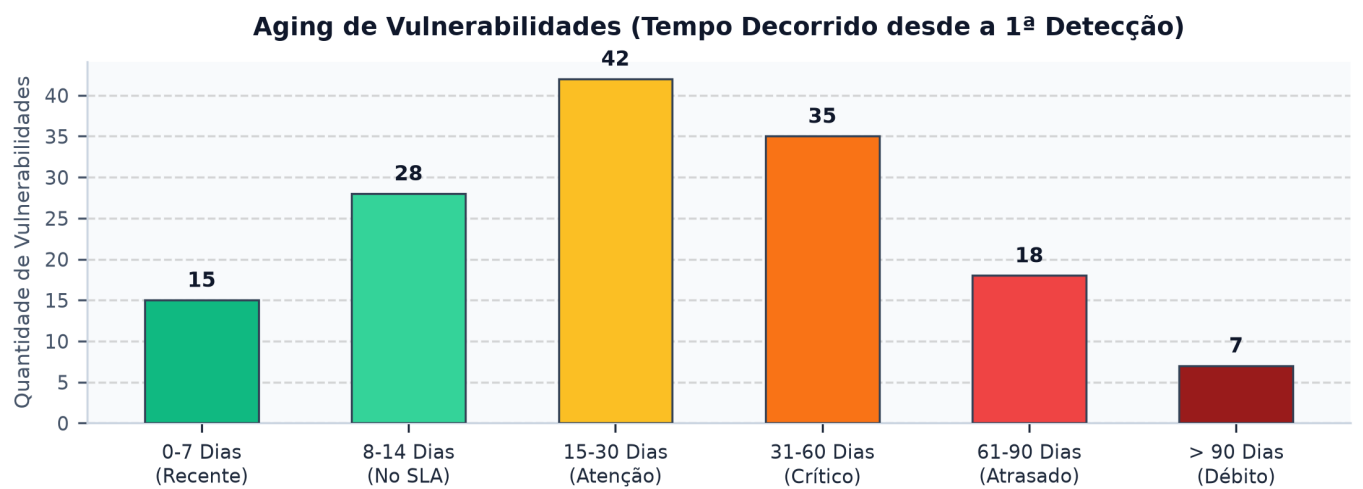


Figura 3: Matriz de Aging de Vulnerabilidades Ativas em 6 Janelas Temporais de Exposição.

4.3 Vetores Ofensivos e Diagnóstico de Qualidade do Scan

Para priorização cirúrgica, o GvulStand correlaciona as vulnerabilidades com inteligência de ameaças públicas (exploits utilizáveis em frameworks como Metasploit, CANVAS e Core Impact). Simultaneamente, o módulo de **Scan Health** monitora a higidez das credenciais utilizadas na varredura.

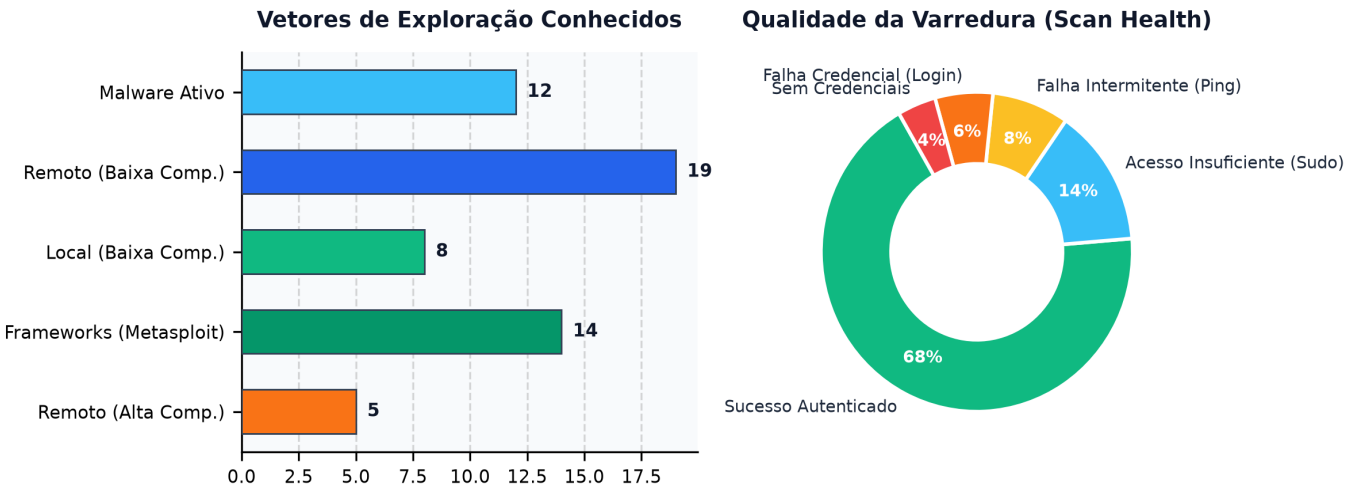


Figura 4: Vetores de Ataque Reconhecidos e Auditoria de Saúde/Autenticação de Scans (Scan Health).

4.4 Motor Comparativo Antes vs. Depois (Eficácia de Remediação ISO 9001)

O módulo comparativo permite selecionar dois scans distintos de um mesmo grupo de ativos para avaliar a eficácia real das tratativas técnicas implementadas pelas equipes de engenharia. O cruzamento diferencial identifica com precisão cirúrgica:

- **Vulnerabilidades Remediadas (Resolvidas):** Apontamentos que estavam presentes no Baseline e não foram mais detectados no scan de Reteste.
- **Vulnerabilidades Persistentes (Mantidas):** Apontamentos que continuam ativos após o período de remediação, demandando escalonamento de SLA.
- **Novas Vulnerabilidades / Regressões:** Vulnerabilidades inéditas introduzidas no ambiente durante o período (ex: novos softwares ou falhas de configuração).

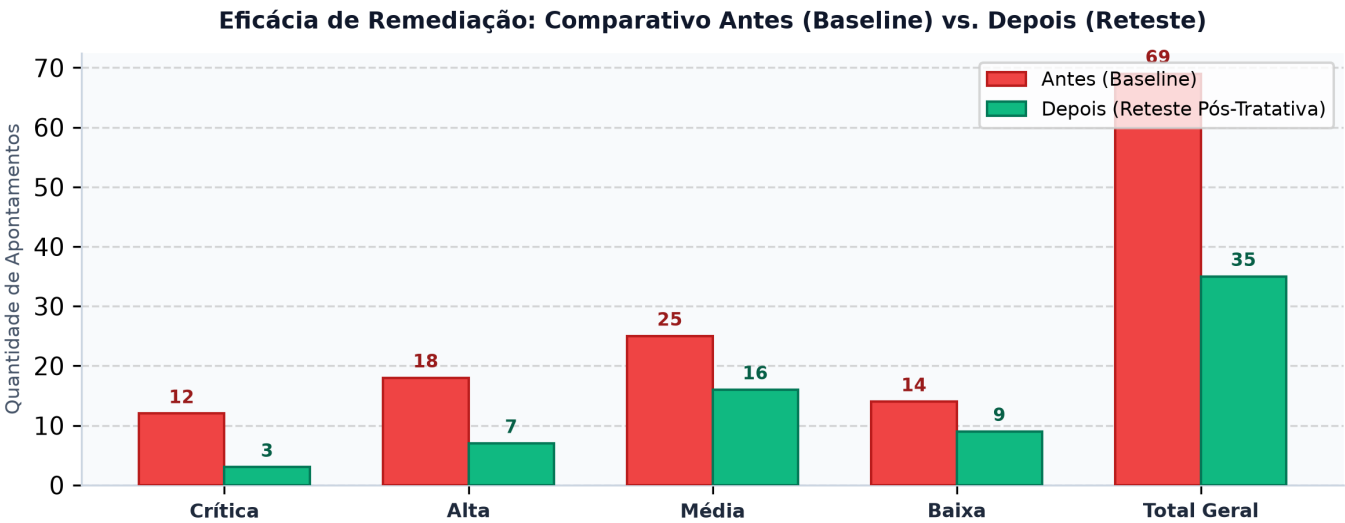


Figura 5: Comparativo de Severidades Antes (Baseline) vs. Depois (Reteste) com Taxa de Resolução.

5. Formulação Matemática e Métricas de Governança

Todas as métricas analíticas e de conformidade do **GvulStand** são calculadas deterministicamente através de formulações matemáticas padronizadas, eliminando subjetividades nos relatórios de auditoria.

FÓRMULA 1: ÍNDICE DE POSTURA DE RISCO ISO/IEC 27001 (CONTROLE 8.8)

$$\text{Postura de Risco} = \frac{(10.0 \cdot N_{\text{Crit}}) + (5.0 \cdot N_{\text{High}}) + (2.0 \cdot N_{\text{Med}}) + (0.5 \cdot N_{\text{Low}})}{\max(1, N_{\text{Hosts Únicos}})}$$

Calcula o risco residual ponderado acumulado normalizado pelo total de ativos únicos em escopo.

FÓRMULA 2: SCORE DE RISCO POR HOST INDIVIDUAL

$$\text{Host Risk Score} = (10 \cdot N_{\text{Crit}}) + (5 \cdot N_{\text{High}}) + (2 \cdot N_{\text{Med}}) + (0.5 \cdot N_{\text{Low}}) + (5 \cdot N_{\text{Crit c/ Exploit}})$$

Adiciona peso ofensivo extra (+5.0) para ativos com vulnerabilidades exploráveis por Metasploit/Malware.

FÓRMULA 3: TAXA DE EFICÁCIA DE REMEDIAÇÃO ISO 9001 (CICLO PDCA)

$$\text{Eficácia de Remediação (\%)} = \left(\frac{N_{\text{Remediadas}}}{\max(1, N_{\text{Total Acionáveis}})} \right) \times 100$$

Mensura o percentual de conformidade de tratativas de segurança sobre vulnerabilidades acionáveis.

FÓRMULA 4: TAXA DE RESOLUÇÃO DO COMPARATIVO (ANTES VS. DEPOIS)

$$\text{Taxa de Resolução (\%)} = \left(\frac{N_{\text{Resolvidas (Reteste)}}}{N_{\text{Baseline (Antes)}}} \right) \times 100$$

Calcula a redução real de apontamentos verificados após a execução do reteste técnico.

FÓRMULA 5: REDUÇÃO LÍQUIDA DE RISCO DO COMPARATIVO

$$\text{Redução Líquida de Risco (\%)} = \left(\frac{\text{Score}_{\text{Baseline}} - \text{Score}_{\text{Reteste}}}{\text{Score}_{\text{Baseline}}} \right) \times 100$$

Quantifica a redução percentual líquida de risco da infraestrutura entre os dois períodos.

FÓRMULA 6: CHAVE ÚNICA DE ASSINATURA DE APONTAMENTO

$$\text{Chave do Apontamento} = \{ \text{Host IP, Plugin ID, Porta, Protocolo} \}$$

Tupla unívoca utilizada pelo motor de diff para rastrear o ciclo de vida e evitar falsos positivos.

5.1 Descrição dos Parâmetros e Pesos Normativos

Parâmetro / Variável	Peso Matemático	Racional de Segurança e Governança
N_Crit (Crítica)	10.0	Vulnerabilidades com CVSS 9.0 a 10.0 que permitem execução remota de código (RCE) ou comprometimento total imediato.
N_High (Alta)	5.0	Vulnerabilidades com CVSS 7.0 a 8.9 que permitem quebra de autenticação, escalção local ou negação de serviço crítica.
N_Med (Média)	2.0	Vulnerabilidades com CVSS 4.0 a 6.9, como XSS refletido, configurações fracas de TLS ou vazamento parcial de dados.
N_Low (Baixa)	0.5	Vulnerabilidades com CVSS 0.1 a 3.9, abrangendo vetores teóricos de baixa relevância isolada.
N_Crit c/ Exploit	+ 5.0 (Extra)	Fator agravante de probabilidade: a existência de arma de ataque pública (Metasploit) eleva drasticamente o risco do host.
Total de Hosts Únicos	Denominador	Normaliza a exposição pelo tamanho do parque tecnológico, viabilizando comparação justa entre redes distintas.

6. Requisitos Técnicos do Sistema

6.1 Matriz de Dimensionamento de Infraestrutura

Recurso	Mínimo (Homologação / Testes)	Recomendado (Produção Corporativa)
Processador (CPU)	2 Cores (x86_64 ou ARM64)	4 a 8 Cores (para parsing concorrente de arquivos de 100MB+)
Memória RAM	4 GB	8 GB a 16 GB
Armazenamento (Disco)	20 GB de espaço disponível	100 GB SSD/NVMe (retenção de histórico de scans)
Largura de Banda	100 Mbps	1 Gbps
Sistema Operacional	Linux (Ubuntu 22.04+, Debian 12+, RHEL 9+) ou Windows Server / 11	Linux Ubuntu 24.04 LTS com Docker Engine 26+

6.2 Requisitos de Rede e Portas de Comunicação

Porta / Protocolo	Origem	Destino	Finalidade Operacional
8000/TCP (HTTP)	Analistas / Auditores / SOC	GvulStand App Container	Acesso à Interface Web SPA e endpoints da API REST FastAPI.
3306/TCP (MySQL)	GvulStand App Container	MariaDB Container	Conexão interna isolada na rede bridge 'gvulstand_net' para persistência.

6.3 Guia de Execução Rápida

Opção 1 - Produção via Docker Compose (Recomendado):

```
docker compose up --build -d
Acesso imediato no navegador em: http://localhost:8000
```

Opção 2 - Execução Local Instantânea (Python 3.12 + SQLite):

```
pip install -r backend/requirements.txt && python run_local.py
(No Windows, execute com um duplo-clique no arquivo start.bat)
```

7. Roteiro Sugerido de Apresentação Executiva

Para demonstrações de alto impacto perante Diretorias, CISOs ou Comitês de Auditoria ISO, recomenda-se a seguinte sequência estruturada em 8 passos:

- Passo 1: Autenticação e Tema (1 min):** Apresentar a tela de login corporativa, demonstrar o alternador de temas Claro/Escuro (adequado a SOC ou auditoria) e autenticar com o usuário Admin ou conta corporativa de rede (Active Directory).
- Passo 2: Visão Executiva do Dashboard (3 min):** Destacar os KPIs de severidade, a contabilização de CVEs únicos dedupados, o Índice de Risco ISO 27001 e a Eficácia de Remediação ISO 9001, comprovando a governança.
- Passo 3: Triagem de Ameaças & Drill-down (2 min):** Acessar 'Top 20 Hosts c/ Exploits' para evidenciar servidores vulneráveis ao Metasploit e 'Top 100 Críticas' demonstrando a Solução Oficial do Fabricante e hosts afetados.
- Passo 4: Ciclo PDCA - Antes vs. Depois (3 min):** Demonstrar o motor comparativo selecionando livremente dois scans ordenados pela data real da varredura (scan_date). Apresentar a Taxa de Resolução (%) e abas de Remediadas, Mantidas e Regressões.
- Passo 5: Tratamento em Massa ISO 27001 (2 min):** No Explorador de Vulnerabilidades, filtrar itens em aberto, selecionar múltiplos registros e aplicar o Bulk Treatment, registrando justificativa e carimbo automático de auditoria.
- Passo 6: Central de Relatórios & Dossiê Técnico (3 min):** Acessar 'Relatórios' e emitir o Relatório Sumário Executivo (com inventário e diagnóstico de EOL de SOs) e o Relatório Técnico Detalhado ativo por ativo otimizado para A4.
- Passo 7: Integração Active Directory / LDAP (2 min):** Demonstrar o teste de conexão ao vivo contra o servidor de diretório e a validação instantânea de sAMAccountName na criação de novos usuários com RBAC.
- Passo 8: Diagnóstico & Troubleshoot (1 min):** Exibir o verificador de falhas de scan, mostrando como a ferramenta orienta a equipe a liberar acessos de firewall e permissões de sudo antes da próxima varredura.

8. Conclusão

O **GvulStand** consolida-se como uma solução robusta, auditável e altamente eficiente para o gerenciamento do ciclo de vida de vulnerabilidades técnicas. Ao traduzir arquivos brutos de varredura em inteligência acionável e alinhar-se perfeitamente aos padrões internacionais **ISO/IEC 27001 (Controle 8.8)** e **ISO 9001 (PDCA)**, a organização assegura conformidade normativa incontestável, otimização dos recursos de infraestrutura e uma postura de cibersegurança comprovadamente eficaz.

Elaborado por: Equipe de Engenharia e Governança GvulStand

Homologação Técnica: Aprovado (35/35 Testes Pytest)

Classificação: Documento Técnico Oficial

Disponibilidade: Formato PDF & Markdown Repositório